SWOT ANALİZİ

Omaksan Makine · Holemaster 1030 MC Plus CNC Delik Delme ve Frezeleme Makinesi

Makine	Holemaster 1030 MC Plus	**Kaynak**	Safety 4.0 Bootcamp laboratuvar föyü (Lab 1–7)
Bakış açısı	Siber güvenlik ve çalışan güvenliği	**Yöntem**	SWOT + risk önceliği

Bu analizde Holemaster 1030 MC Plus'ı laboratuvarlarda işlediğimiz bilgilerle değerlendirdim. Makinenin satış veya fiyat tarafına bakmadım, siber güvenlik ve çalışan güvenliği açısından güçlü ve zayıf yönlere odaklandım. Çünkü bu makinede bir siber saldırının sonu, makinenin başındaki kişinin zarar görmesi olabilir. Üretici dokümanına ulaşamadığım için emniyet devresi, yazılım sürümleri ve uzak servis yapısı gibi bazı bilgiler varsayıma dayanıyor ve üreticiden doğrulanmalı.

1. SWOT matrisi

GÜÇLÜ YÖNLER (S)

- **Çok işlevli:** tek makinede delik delme, kanal açma ve frezeleme yapılabiliyor.
- **Programla çalışır:** delik sırası ve eksen hareketleri CNC programıyla yönetildiği için iş tekrarlanabilir.
- **Küçük saldırı yüzeyi:** standart makinede robot, SCADA veya yapay zekâ modülü yok varsayıldı; bağlı olduğu sistem az.
- **Ayrı emniyet yolu:** E-stop, kapı kilidi ve STO normal kontrolden ayrı bir safety yolunda kurgulanabiliyor.
- **Bölgelere ayrılabilir:** safety, makine kontrol, hazırlık ve ofis ağı ayrı bölgelerde tutulabilir.

ZAYIF YÖNLER (W)

- **Teknik bilgi eksik:** üretici dokümanı incelenmedi; emniyet devresi ve PLr/SIL düzeyi doğrulanmadı.
- **Uzak erişim zayıf olabilir:** doğrudan bağlantı, ortak hesap, sürekli açık ve kayıtsız yapı olasılığı var (varsayım).
- **Emniyet yazılıma bağlı olabilir:** kapı/E-stop sinyali CNC yazılımından geçiyorsa saldırgan emniyeti de etkiler.
- **Kontrolsüz girişler:** USB ile program yükleme ve HMI servis menüsü.
- **Yazılım envanteri yok:** SBOM, firmware sürümü ve CVE bilgisi bilinmiyor.

FIRSATLAR (O)

- **Güvenli uzak bakım:** jump server, VPN, MFA, kişisel hesap ve kayıtlı oturum.
- **Ağ bölümleme:** ofis ağı, CAD/CAM bilgisayarı ve makine kontrol ağı birbirinden ayrılabilir.
- **Kayıt tutma:** parametre yedekleri, değişiklik geçmişi ve USB kullanım kaydı.
- **Yama yönetimi:** üreticiden SBOM ve yama takvimi istenebilir; yamalar önce test edilir.
- **Ucuz önlemler:** bypass için süre sınırı, ikinci kişi onayı ve vardiya kontrol listesi.
- **Kalite kontrol:** kamera/YZ eklenirse insan onayı ve ikinci kontrolle kullanılabilir.

TEHDİTLER (T)

- **Çalınmış servis hesabı:** kapı kilidi veya STO ayarı uzaktan devre dışı bırakılabilir.
- **Hatalı veya sahte program:** USB ile gelen yanlış koordinat takımın çarpmasına, parçanın fırlamasına yol açar.
- **Unutulan bypass:** bakımda açılan koruma kapatılmazsa sonraki vardiyada yaralanma riski doğar.
- **Yamasız açık:** ulaşılabilir bir kritik zafiyet üretimi ve güvenliği tehlikeye atar.
- **Kanıt kaybı:** olayda "resetleyip devam" kanıtı siler, bildirim süreleri kaçar.
- **YZ hatası:** eklenirse kusurlu parçayı sağlam sayabilir.

Not: Emniyet rölesi/PLC ve STO, föyde anlatılan hedef mimarinin parçalarıdır. Makinede gerçekten bulunup bulunmadıkları üretici dokümanlarından doğrulanmalıdır.

2. Tehditlerin önceliği

Üçüncü laboratuvarda üç senaryoyu L (olasılık) × S (şiddet) × E (maruziyet) ile puanlamıştık. En yüksek puan alan iki senaryo, hem makineyi hem insanı etkilediği için SWOT'taki en önemli tehditler. Üçüncüsünün skoru düşük çıksa da şiddeti 3 (ağır yaralanma) olduğu için listeden çıkarmadım. E değeri föyde açıklanmadığı için varsayım.

Tehdit senaryosu	L	S	E	Skor	Öncelik
Çalınmış servis hesabıyla kapı kilidi/STO'nun kapatılması, açık kapakta iş mili dönmesi	2	3	2	**12**	Yüksek
USB ile bozuk koordinatlı program, takım kırılması ve parça fırlaması	3	2	2	**12**	Yüksek
HMI servis menüsünden açılan bypass'ın kapatılmaması	1	3	1	**3**	Düşük, ama S=3 olduğu için öne alındı

3. Stratejik yorum

Dört başlığı birbirine bağlayınca ortaya şu çıkıyor:

	Güçlü yönler (S)	Zayıf yönler (W)
Fırsatlar (O)	Küçük saldırı yüzeyini ve ayrı safety yolunu, VPN/MFA ve ağ bölümlemeyle birlikte kullanıp korumak.	Zayıf uzak erişimi jump server, MFA ve kişisel hesaplarla kapatmak; üreticiden SBOM istemek.
Tehditler (T)	Emniyeti donanım devresinde tutmak; hesap çalınsa bile kapı kilidi ve E-stop uzaktan kapatılamasın.	USB'yi taramadan geçirmek, bypass'a süre ve onay koymak, yedek ve kayıt tutmak.

4. Geliştirme önerilerim

Önerileri risk puanına göre sıraladım. İnsan sağlığını doğrudan etkileyenleri başa aldım.

1	**Emniyet sistemini doğrulamak** E-stop, kapı kilidi ve STO'nun gerçek bağlantıları üreticiyle kontrol edilmeli, yetkili kişilerce test edilmeli.	**Yüksek**
2	**Uzak erişimi korumak** VPN ve MFA kullanılmalı, erişim yalnızca serviste açılmalı, herkesin kişisel hesabı olmalı, oturumlar kaydedilmeli.	**Yüksek**
3	**USB ve programları kontrol etmek** USB dosyaları taranmalı; program çalışmadan önce koordinat, takım ve fikstür kontrolü yapılmalı.	**Yüksek**
4	**Bypass'ı sınırlamak** Bypass süreli olmalı, ikinci kişi onayı gerekmeli, vardiya devrinde korumaların aktif olduğu kontrol edilmeli.	**Yüksek**
5	**Yedek ve kayıt tutmak** CNC ayarları yedeklenmeli, bakımda yapılan değişiklikler kaydedilmeli.	**Orta**
6	**Yazılım açıklarını takip etmek** Üreticiden yazılım ve firmware sürümleri istenmeli; yama önce test edilip sonra uygulanmalı.	**Orta**
7	**Ağları bölümlere ayırmak** Ofis bilgisayarları ile makine kontrol ağı ayrılmalı, yalnızca gerekli iletişime izin verilmeli.	**Orta**

8	**Olay planı hazırlamak** Şüpheli erişimde önce insan güvenliği sağlanmalı, bağlantı kontrollü kesilmeli, kayıtlar silinmeden korunmalı.	**Orta**
9	**YZ varsa ikinci kontrol koymak** Yapay zekâ sonucu makineyi tek başına yönlendirmemeli; şüphede operatör onayı veya güvenli duruş devreye girmeli.	**Düşük**

5. Sonuç

Holemaster 1030 MC Plus için yalnızca üretim kabiliyetine bakmak yetmiyor. Makinenin mimari fikri iyi: emniyet normal kontrolden ayrı ve ağ bölgelere ayrılabiliyor. Asıl risk bu ayrımın pratikte bozulması. Uzak servis hesabı, USB ile program aktarımı ve koruma bypass'ı emniyet fonksiyonuna ulaşabilecek en olası üç yol olarak öne çıkıyor. Bunların çoğu pahalı olmayan önlemlerle kapatılabilir.

Karar vermeden önce üreticiden makinenin gerçek donanımı, yazılım sürümleri ve emniyet düzeyi hakkında bilgi alınmalı. Bu çalışmadan çıkardığım sonuç şu: bir saldırı zinciri "veri çalındı" ile bitiyorsa emniyet bulgusu sayılmıyor, bir adım daha gidip bunun makinenin başındaki insana ne yapacağına bakmak gerekiyor.